

Validation Risk Register

RISK ID	RISK DESCRIPTION	SOURCE EVIDENCE	PROBABILITY	IMPACT	RISK LEVEL	MITIGATION
VR-01	Content Security Policy (CSP) Header Not Set	OWASP ZAP Scan Report	High	High	Critical	Implement Content-Security-Policy header to restrict trusted content sources and prevent script injection attacks.
VR-02	Cross-Domain Misconfiguration	OWASP ZAP Scan Report	Medium	High	High	Configure proper CORS policies to allow access only from trusted domains.
VR-03	Server Leaks Version Information via "Server" HTTP Response Header	OWASP ZAP Scan Report	Medium	Medium	Moderate	Hide or disable server version details in HTTP response headers.
VR-04	Strict-Transport-Security (HSTS) Header Not Set	OWASP ZAP Scan Report	High	High	Critical	Enable Strict-Transport-Security header to enforce

						HTTPS connections.
VR-05	Timestamp Disclosure – Unix	OWASP ZAP Scan Report	Low	Low	Low	Remove unnecessary timestamp exposure from application responses.
VR-06	Modern Web Application Detected (Informational)	OWASP ZAP Scan Report	Low	Low	Informational	No mitigation required; informational finding only.
VR-07	Re-examine Cache-control Directives	OWASP ZAP Scan Report	Medium	Medium	Moderate	Configure secure Cache-Control, Pragma, and Expires headers to prevent sensitive data caching.